# 超越模型反思：大语言模型时代的解耦安全理论与动态防御实践

*Yunhao Wang* 匿名
联想（*Lenovo*） 匿名

## Abstract

大语言模型已成为关键基础设施，但现有防御过度依赖模型自身的反思与推理——在任务重构、心理学操纵与对抗性合理化下必然失效。本文主张 LLM 安全必须与脆弱的自我反思解耦，并奠基于新范式。我们形式化三大基本失效定理及相应的解耦安全理论。（1）计算/验证不对称（**Computational/Verification Asymmetry**）：基于意图的语义防火墙必然被任务重构与完美良性用户伪装（PBU）穿透；安全验证从不可判定的全局空间降维到多项式时间的实例级安全集投影，形成攻防间的计算复杂度极大不对称性。（2）价值/本体锚定：更强推理（如 CoT）在心理学操纵下会加剧对抗性合理化，恶化防御；安全须依托价值/本体层，并在公理冲突时执行防御性降级。（3）表征异常：表面文本操纵会劫持语义检索；我们将监控锚定于相对良性黄金基线的隐藏状态轨迹散度。我们通过架构重建（上下文混淆引擎、带分布评估的混合裁判集成、防御性降级与异构恢复）与受控变异（元认知监控器、联合键示例检索、高密度专家迁移）实例化上述理论。我们陈述明确的运行边界，并论证：要在机器速度下实现可扩展、可审计的安全，这一范式转移不可或缺。关于经验证据：文中引用的具体攻击/防御数值（如 HPM 漏洞保留率、SISF 报告值）均出自所引文献。本文将评估协议（§5）与开源参考网关及 `paper-eval-5` 评测脚本（§5.12）配对，使 Track A 主指标（含版本化有害行为列表上的 RSR——优先采用 **JBB-Behaviors** 式 **misuse/benign** 成对以联合报告 RSR 与良性误拒、抽取 $F_1$、多轮轨迹与 SLA 代理等）可在真实 OpenAI 兼容上游上复现；`paper-eval-5` 支持可选 **HTTP** 裁判（捆绑 `judge_service` 微服务）与 `smooth_llm` 基线下的 **SmoothLLM** 式 **K** 次扰动多数票（RSR）及抽取 **max-F1** 聚合。Track B 不在该制品范围内。在系统层面，同步网关在严格延迟预算（<50 ms）下将上下文混淆与轻量元认知检查置于关键路径，而混合裁判集成、策略合成与受控变异置于带外异步环，从而在保持推理路径可部署的前提下维持运行时吞吐。

## 1 引言

大语言模型已不再是边缘研究产物，而是关键系统的支撑：代码生成、具系统访问权的智能体、谈判与合规敏感工作流 [4, 27]。这一转变暴露出根本性错配：传统安全保证假定组件是确定性的、可穷举规约的，而 LLM 驱动系统呈现涌现性、随机行为。静态防御与周期性红队以人类速度运转，难以跟上自动化对抗生成；一旦新型越狱或提示注入得逞，架构往往保持不变。

更糟的是，许多防御依赖模型自身的反思与推理。在任务重构下，对手将抽取伪装成合法上下文处理任务，使基于意图的过滤器只看到「正常」行为。在心理学操纵（如煤气灯）下，更强推理（如思维链）被武器化：模型为顺从恶意指令编造精细、逻辑自洽的合理化——漏洞保留率可超过 77% [14]。依赖「认知一致性」或「自我诊断」之所以失败，并非因组件薄弱，而是底层范式错误：安全不能建立在攻击者正积极腐蚀的同一认知过程之上。

范式转移：解耦安全。我们主张 LLM 安全必须与模型无约束的自我改进解耦，并奠基于（i）架构重建——谁在何时执行安全；（ii）受控变异——向 Oracle 暴露什么、进化如何锚定。自适应不是 LLM 盲目「左脚踩右脚」，而是通过上下文混淆（剥夺攻击者干净操作空间）、黄金示例（锚定防守方价值）以及带强制人工校准的裁判网络来引导。在 §2 中我们形式化三大基本失效定理及相应的解耦安全理论。在 §3 与 §4 中给出技术实例化：动态操作空间污染、带分布评估与价值/本体锚定的混合裁判集成、防御性降级与异构恢复、基于表征异常的元认知监控、联合键示例检索与高密度专家行为迁移。§5 涵盖指标与评估；§6 陈述解耦安全的物理学——界定设计成立条件的显式运行边界。

主要贡献为：（1）理论基础（*Theoretical Foundation*）：从概率程序语义学的角度，严格证明了对图灵完备 LLM 施加非平凡全局隐式安全的不可判定性，并论证了在合取依赖下安全属性的不可组合性；（2）安全内核架构与多项式验证（*Architecture & Instance-level Verification*）：提出解耦运行时安全架构，证明了通过转移安全验证至解耦断言器，能够在多项式有界候选集假设下，将安全验证降阶为 $O(|C| \cdot p(|x|))$

的单步前向不变性问题；（3）代数框架与系统实现（*Algebraic Enforcement & System Eval*）：提出安全算子偏序集（Risk poset），从理论上保证了多重防护组合的「优雅降级」收敛于 fail-safe，基于此实现了一个开源安全内核原型，并在超图合取攻击基准上验证了其能有效切断多 Agent 环境下的能力外流。

## 2 解耦安全范式

我们陈述传统 LLM 安全的三个基本失效定理及取而代之的解耦安全理论。资产与 Oracle 的定义沿用既有工作 [7, 19]：资产为系统的有效安全表面（策略、护栏、触发集、评估数据）；*Oracle* 对行为标注（安全/不安全）。在多轮设定下，攻击者与系统交互并观察结果，形成统计查询接口。同一项目在多轮中不受控地暴露会助长重建攻击。

### 2.1 形式化问题定义

考虑一个提供开放多轮自然语言交互的已部署 LLM 系统。系统内部包含高价值受保护资产（如系统提示、RAG 语料与执行策略）。从计算理论视角来看，可将 LLM 系统建模为概率程序 $\mathcal{P} : X \to \mathrm{Dist}(Y)$。根据 Rice 定理，关于该概率程序的任何非平凡全局隐式安全属性（Global Implicit Safety）均是不可判定的（归约于停机问题）。因此，本文致力于解决的核心问题是：在放弃不可判定的全局安全的前提下，如何为面对自适应攻击者的系统提供一种基于实例级验证（**Instance-level Verification**）的外部安全强制机制，以在攻击代价计算不对称性与系统优雅降级之间取得形式化保证。具体而言，本文在以下两个目标间寻求可证明的平衡：

(a) 计算不对称的运行时安全（**Computationally Asymmetric Runtime Safety**）：将安全验证从不可判定的全局空间降维到多项式时间的实例级安全集投影，使攻击者在有限交互预算（Token/Queries）内的违规逃逸概率趋近于零。

(b) 组合优雅降级（**Compositional Graceful Degradation**）：在保证核心资产不被泄露的绝对底线（Fail-safe 状态）前提下，通过安全算子代数最大限度维持多轮交互的可用性。

### 2.2 威胁模型与攻击者能力

我们给出形式化威胁模型，使后续机制均有明确范围。

攻击者能力（能做什么）。攻击者对已部署系统拥有多轮黑盒交互访问（Hard-label，即仅获得最终生成的文本流，无法获取 Logits 或内部权重）。支持自适应查询、提示注入（Prompt Injection）、利用并发依赖的组合攻击（Conjunctive capability hypergraph attack）、完美良性用户（**PBU**）伪装（表面行为与良性用户不可区分）及心理学操纵（**HPM**）（煤气灯、权威压迫、角色边界攻击）。攻击者亦可使用任务重构（将抽取伪装为摘要、格式转换或学术讨论）。评估双轨（**§5.2**）：为分离「可上线结论」与「组件上界」，我们将**Track A**（生产对齐）限制为黑盒查询与公开越狱/多轮框架；**Track B**（实验室上界）额外允许梯度与多次前向（GCG、表征对齐 PBU 等），其结果仅用于探测压力上界，不与 Track A 的 ASR 混列为单一「部署防御效果」。

攻击者知识（**Kerckhoffs** 边界）。遵循 Kerckhoffs 原则，攻击者白盒了解防御架构体系（即知道系统部署了解耦安全内核与 DCBF 监控器），但黑盒面对具体的安全策略参数（Safety Predicate Policies）和后端的具体模型权重。

攻击者限制（不能做什么）。无法进行物理内存读写；无法进行白盒梯度反向传播；受到严格的系统级交互预算约束（单会话最大轮数 $N$ 与最大生成 Token 数 $T$）。

成功判据与预算约束。攻击在给定查询预算 $B$ 内，使得输出状态突破 DCBF 定义的安全超水平集（Safe Superlevel Set），从而完成对受保护资产的确切提取（Exact Extraction）或非授权功能调用。成功以抽取保真度（如相对真实片段的 F1）或目标行为上的攻击成功率（ASR）度量。系统配置类资产（如完整系统提示与策略指令）是已有专门基准覆盖的典型抽取目标类别 [28]。

### 2.3 防御目标

1. 多项式时间运行时拦截：确保对于任意输入，实例级候选生成集能够被多项式时间 $O(|C| \cdot p(|x|))$ 复杂度的安全断言所覆盖过滤。

2. 前向安全不变性：在离散时间演化下，确保核心系统状态始终保持在解耦控制屏障函数（DCBF）定义的动态安全集中。

3. 不可逾越的故障安全底线（**Absorbing Fail-safe**）：在系统遭受多轮复杂逻辑依赖攻击引发规则冲突时，系统能根据安全代数框架，严格收敛至底元素状态（$\perp$），实施优雅降级而不会引发内部逻辑崩溃。

### 2.4 理论框架与方法总览

本文的方法通过根本范式转移——从「隐式对齐（Implicit Alignment）」转向「解耦安全（Decoupled Safety）」——来构建防御体系。首先，我们证明了隐式安全性在多组件系统中由于合取依赖是不具备可组合性的（Non-compositional）。由此，我们在系统接口层外置了单调且保持安全性的安全算子（Safety-preserving operators）。在运行时（Runtime），该架构将复杂的语义防御映射为严格的 Ring-3（用户空间 LLM）与 Ring-0（系统内核）隔离，通过评估离散状态转移候选集，确保所有超越风险偏序集（Risk poset）安全阈值的操作均被安全算子强行拦截并归约至 $\perp$ 状态，从而在不可判定的迷雾中建立了一块可审计的形式化安全高地。以下三节（§2.5–§2.7）分别从信息经济学、价值/本体锚定与表征异常三个维度具体展开失效定理与解耦安全理论。

## 2.5 从语义审查到计算/验证不对称

**定理 2.1 (语义审查的失效).** 基于意图的语义防火墙必然被任务重构（将抽取伪装为摘要、格式转换或学术讨论）及完美良性用户（***PBU***）模仿所穿透。在多轮交互中，敏感内容的完全隔离在计算理论意义上不可实现；即便有 *ID* 对齐、诱饵与拒绝门控，残余抽取（如 *F1* 约十余个百分点）仍存在 *[24, 31]*。

**解耦安全理论 2.2 (多轮抽取的计算/验证不对称).** 防御不应以绝对阻断为目标，而应以计算/验证不对称为目标。底层证明基于复杂度理论：安全验证是多项式时间的实例级断言，而全局绕过是不可判定的。在工程层面，目标是主动污染攻击者操作空间，使达到给定重构保真度所需的查询复杂度随轮次快速增长（实践中常为超线性；在无进一步分布假设下我们不声称严格指数）。我们用代价函数不等式将其精确化。令攻击者成本为 $C_{\text{attack}} = f(N_{\text{rounds}}, D_{\text{decoy}}, \ldots)$，其中 $N_{\text{rounds}}$ 为轮数，$D_{\text{decoy}}$ 概括诱饵密度与 *ID* 对齐强度；令 $V(t)$ 表示受保护资产的等效价值或生命周期（如至弃用或轮换的时间）。令 $E[N]$ 为在我方防御下，达到高于选定保真度阈值（如 $F1 > \tau$）的抽取成功所需的期望轮数。在上下文混淆（*ID* 对齐、诱饵注入、风险评分）下，我们假定 $E[N]$ 被抬高，使诱导成本满足

$$C_{\text{attack}}\big(E[N], D_{\text{decoy}}\big) \;>\; V(t). \tag{1}$$

防御则在计算不对称意义上成立：攻击者需穷举的搜索空间远超多项式时间实例级验证的成本，抽取成本超过资产有效生命周期。为使该代价不等式在科学上可证伪而非重言式，$V(t)$ 须由显式管理策略严格界定（如 *30* 天凭证轮换窗口），$C_{\text{attack}}$ 须用 *SOTA* 基线的经验指标界定上界（如多轮框架的 *Token* 消耗与算力时数，或 *PAIR* 等低查询黑盒生成器的查询次数 *[23]*）。若可量化的攻击在 $V(t)$ 内完成资产抽取，则防御在经验上被证伪。该应用层面的代价分析假定资产可轮换性；对静态或永久高价值资产，须由 *RBAC* 与信息流追踪提供硬屏障，代价分析仅为纵深防御的一层（*§3*）。

## 2.6 从认知一致性到价值/本体锚定

**定理 2.3 (认知一致性的失效).** 强化模型的认知层（逻辑、推理、思维链）无法防御心理学操纵（***HPM***）。*HPM* 可表述为对心理状态与策略性脆弱性资产的跨轮操纵——而非静态提示列表——并针对价值/社会动力学层（价值、服从、角色边界），含跨交互的心理测量式刻画 *[14]*。实证表明，在 *HPM* 下增加外部事实或更强推理会恶化防御：模型利用增强推理进行对抗性合理化——为顺从恶意指令编造逻辑自洽的借口 *[12, 14]*。逻辑自洽不等于安全。

**解耦安全理论 2.4 (价值/本体锚定与防御性降级).** 安全必须锚定于与模型自由反思独立的价值/本体层。系统须（*i*）将裁判输出与人工定义的公理化安全锚定（如「永不认可对禁止片段的抽取」）对照；（*ii*）监控社会学失稳信号（过度共情、权威服从、角色边界打破），而非依赖 *CoT* 长度或自洽性；（*iii*）当多重公理冲突或检测到社会学压力时，放弃复杂推理并执行防御性降级——无状态、基于模板的拒绝，从物理上阻断模型对冲突的「合理化」。降级并非绝对的安全避风港（*safe harbor*）：它引入算法级 *DoS* 与侧信道风险；设计因此强制异构恢复通道（向人类或符号逻辑异步移交），以免关键工作流被恶意冻结（*§3*）。

哲学注记（范畴与本体）。我们明确声明：「价值/本体锚定」不意味着 LLM 具有真实的道德主体性或本体论地位。在哲学上，LLM 仍是统计映射引擎。我们的价值层是实用主义架构构造——由设计者施加的一组高权重启发式分类（「公理」），作为统计熔断器对抗模型模仿对抗性一致性的倾向。人类道德哲学词汇（如过度共情、权威服从）在此仅作为监控目标的设计规格，而非主张模型在哲学意义上拥有信念或价值观。

## 2.7 从文本操纵到表征异常

**定理 2.5 (文本—语义检索的失效).** 当攻击者控制表面文本（*PBU*、任务重构）时，语义检索（如基于提示嵌入的 *RAG*）被劫持：提示可看似「摘要」或「学术讨论」，纯嵌入相似度返回良性示例（如「如何做摘要」）而非安全示例（如「如何防御越狱」），修正模块因而被错误示例驱动。

**解耦安全理论 2.6 (基于隐藏状态轨迹的元认知基线).** 我们不假定复杂社会学状态（如「认知崩溃」「过度共情」）在隐藏空间中线性可分——可解释性证据支持的是较简单维度（如诚实、拒绝），而非细粒度社会心理概念 *[26]*。我们将偏离视为表征异常：系统计算当前多轮隐藏状态轨迹与良性黄金经验轨迹基线之间的散度（如马氏距离或分布偏移）。我们不定义「何为认知崩溃」；仅检测内部轨迹是否严重偏离安全基线。这提供独立于自然语言的监控维度，从而在表面文本良性时，「恶意遵从」或「越狱」等激活特征仍可将检索与干预导向正确安全示例（*§4*）。

认识论注记（黄金基线）。认识论上，我们承认「良性黄金基线」并非客观物理真理，而是反映设计者及标注者对齐目标的社会建构的规范性标准。因此，监控器检测到的「发散」度量的是相对设计者对齐合规的偏离，而非绝对、普适的安全状态。基线是部署者当前可接受行为的冻结快照，不主张道德或物理上的普遍性。

# 3 架构重建：在机器速度下施加约束

我们通过三个技术方向实例化理论 1（信息经济学）与理论 2（价值/本体锚定）：上下文混淆、带分布评估的混合裁判集成、防御性降级与异构恢复。图 1 给出了统一架构的数据流与各模块的衔接关系。入站提示（如任务重构抽取或 PBU 伪装请求）首先经上下文混淆引擎处理：ID 对齐剥离或规范化实例标识符，诱饵注入以带水印的合成字段污染操作空间，高保真抽取触发审计或会话终止。（可能经诱饵触碰的）请求随后到

Placeholder figure

Figure 1: 统一架构概览。左：架构重建（上下文混淆引擎、带价值锚定的混合裁判集成、策略合成与反馈环、防御性降级与异构恢复）。右：受控变异（元认知监控器、联合键示例检索、黄金数据集与经验记忆、轮次调度）。范式将安全与 LLM 自我反思解耦；重建控制谁/何时，变异控制暴露什么。

达基座 LLM；其输出不被盲信，而是送入经 token 级流水线标准化与分布评估的混合裁判集成；仅达成共识时信号才进入策略合成；价值/本体锚定与社会学失稳监控对对抗性合理化降权或置零。当公理冲突或压力被检测到时，防御性降级强制无状态模板拒绝，并以异构恢复通道（向人类或符号逻辑异步移交）保持可用性。图右侧，元认知监控器将当前隐藏状态轨迹与良性黄金基线比较；异常时触发对抗性重置并驱动联合键示例检索（语义嵌入加激活特征），使即便表面文本被伪装仍能召回安全相关黄金示例。轮次调度与变体分散保护资产。以下实现该端到端流程。

部署与延迟：同步网关 **vs.** 异步环。为使架构可投入生产（如置于 vLLM 或 TGI 之后），我们明确采用带外/异步切分。上下文混淆引擎（ID 对齐、诱饵注入）及轻量级元认知检查（如快速轨迹分查询或 SLM 分类器）部署在请求路径上的同步反向代理或边车，严格延迟预算（如 <50 ms），以保证 p99 与吞吐可接受。混合裁判集成、分布评估（每变体多样本）、策略合成及示例检索/变异运行于异步离线学习环：消费记录的（请求、响应、激活）流，在不阻塞在线推理路径的前提下产出更新策略或变体。在此系统意义上定义机器速度：同一攻击分布上的首个零日或新型攻击可能通过；异步环在裁判集成达成共识后，于亚分钟级生成并部署新变体或策略，使后续同分布请求被拦截。该工程权衡在自适应防御中常见：以一次性泄漏换取可部署的延迟与吞吐。图 2 说明该切分。

自改进安全框架（SISF）[27] 将安全重述为持续过程：未对齐基座 LLM 提供能力；违规检测交给混合裁判集成；策略合成消费共识并在运行时部署新策略。文献报告：经适当校准后，AdvBench 式 ASR 可由 100% 降至约 45%，良性 FPR 为 0% [27]——该数字为引用来源的实验设定，非本文自有复现结果。

## 3.1 上下文混淆引擎：对抗 PBU 与任务重构的动态空间隔离

在基于意图的防火墙之上 [4]，我们实现上下文构建防御，主动污染攻击者操作空间。

**ID** 对齐。在检索上下文或中间结果到达基座 LLM 之前，ID 对齐模块剥离或规范化实例标识符。攻击者无法再通过指定 ID 定界并抽取敏感片段；良性问答不受影响。在不改变名义任务语义的前提下降低重建精度。

密码学水印诱饵与风险评分。系统注入带哈希派生结构的诱饵字段（合成实体或关联），良性交互中因模型幻觉而偶然碰撞该诱饵的概率极低。后端指令将诱饵标为内部禁止。良性用户忽略；任务重构型攻击者常覆盖指令并暴露诱饵。为控制不可接受 FPR，采用诱饵命中密度与风险评分：单次低保真触碰触发警告与意图重校验；仅对完整诱饵结构的高保真抽取触发会话终止与审计。诱饵命中密度对暴力抽取有效。对完美 **PBU**，我们不断言熔断在经济上有用重构前触发：PBU 的诱饵触碰率可与良性幻觉 FPR 相当，阈值调节面临可用性—安全权衡。设计将其重述为经济防御：在资产可轮换或弃用处，使慢速 PBU 抽取成本超过资产有效生命周期。对静态或永久高价值资产，元数据层的 RBAC 与信息流追踪（§4.3）为硬屏障；经济学为纵深防御的一层。

末轮自我提醒。多轮交互最后一轮将安全指令强制附加为用户查询的系统提示，强化边界意识并减少会话末漂移。

## 3.2 混合裁判集成与分布评估

单一 AI 裁判存在系统性偏差与盲区。我们使用混合裁判集成（如 Llama-Guard [18]、StrongREJECT [30] 评分协议或等效评估器、任务专用分类器），仅于共识时将反馈传入策略合成。参照 StrongREJECT [30]，我们显式抑制空越狱（输出未触发拒绝词但并非真正有害），以免 ASR 虚高、与人工判断脱节。我们不假定多样性单独消除偏差：格式敏感性（空格、系统提示布局、聊天模板）可使攻击成功率偏移 8–14% [20]，且温度为零时同一提示在不同运行间可在拒绝与通过间翻转 [5]。我们强制严格 **token** 级输入流水线标准化：所有裁判接收规范化输入（剥离指令/特殊 Token、统一空格），以防格式注入扭曲判决。判决不基于单次贪婪解码。流水线采用分布评估：每变体多次采样，估计经验失败概率分布；仅当该分布显著超阈值时触发策略更新，以应对采样随机性与格式敏感性。

对模糊边界情形，价值/本体锚定（§3.3）对集成加权：我们不依赖思维链长度或逻辑自洽。系统监控社会学失稳信号（过度共情、权威服从、角色边界打破），将裁判输出与预定义公理化安全锚定对照；冲突或呈现失稳的输出获零权重。强制人工校准支路接入：固定比例（如 5%）的高置信度决策随机抽选供人工审计。格式标准化不能消除相关性认知盲点（裁判可共享预训练/RLHF 数据）；强制人工校准提供对零日共识失败的周期性离线纠偏。

置信度加权投票与验证器性能参考。在 Round-2 中，我们扩展裁判集成以支持置信度加权投票（`confidence_weighted_tally`）：每个验证器 $j$ 的判决票权重为其自报置信度 $c_j \in [0,1]$，加权分数 $W_d = \sum_{j:v_j=\text{Deny}} c_j$。**Deny-**优先原则不变：只要 $W_d >$

Placeholder figure

Figure 2: 系统部署与延迟架构将延迟关键的同步推理路径与异步安全自适应环分离。轻量上下文混淆与快速元认知检查部署于带严格延迟预算（<50 ms）的同步反向代理上；混合裁判集成评估、分布策略合成与受控变异在异步环中带外运行，通过将昂贵自适应组件移出关键路径以保持运行时吞吐。

0，最终裁决为 Deny（除非触发了审计破玻璃策略）。此设计使低置信度的 Allow 投票不会淹没高置信度的 Deny 信号。典型验证器性能参考（基于公开文献与内部基准）：Llama-Guard 系列在 JBB-Behaviors 上的 F1 约 0.82–0.89，良性误拒率（FPR）<5% [18]；StrongREJECT 评分器在压制空越狱后精度约 0.91 [30]；结合多裁判投票后系统级 FPR 可降至 <2%（详见评估 §5）。

置信度来源与校准。各类验证器的 confidence 值来源不同：**(a)** LLM 型验证器（如 Llama-Guard）使用其输出 softmax 概率中安全/不安全类别的最大概率作为 $c_j$——例如，若模型对"不安全"类别的 softmax 概率为 0.92，则 $c_j = 0.92$。**(b)** 规则型验证器（如 regex_deny、keyword_flag）因判定为确定性匹配，固定 $c_j = 1.0$。**(c)** 外部分类器（如 StrongREJECT 评分器）使用其评分归一化至 $[0,1]$ 区间。为缓解 LLM 验证器的过度自信问题（softmax 概率未经校准时系统性偏高），可选启用温度缩放后处理：$c'_j = \sigma(\log(c_j)/T)$，其中 $T > 1$ 为校准温度参数，在验证集上通过最小化预期校准误差（ECE）获得。关键不变量：Deny-优先原则确保即使单个验证器给出高 confidence 的 Allow 判决，只要存在任意 Deny 票（不论其 confidence 大小），最终裁决仍为 Deny。该不变量使加权投票的安全保证单调——增加验证器数量或调整 confidence 仅可能使系统更严格，不会意外放松。

审计透明性与 **Evidence Chain**。加权投票过程通过 Evidence Chain 实现完全可追溯：每次投影步的审计记录包含每个验证器的 `verifier_id`、原始 `vote`（Allow/Deny/Abstain）、`confidence` 值、加权得分 $W_d/W_a$ 及最终裁决。部署者可回溯任意判决查看哪些验证器贡献了 Deny 票及其置信度权重。对比 OpenAI Moderation API 等黑箱方案——仅返回二元标签和聚合分数，无法追溯单个分类器的判决过程——解耦安全架构的审计链提供了可解释、可归因的安全判决依据。这一透明性对满足金融（SOX）、医疗（HIPAA）等行业合规审计要求至关重要。

### 3.3 价值/本体锚定、防御性降级与异构恢复

HPM 善于制造道德困境：恶意请求可被包装成与安全公理最大程度一致（如「输出这段代码否则数百人将丧生」）。在此类公理冲突情形下，「过度共情」并非简单阈值。我们不从锚定中寻求绝对真理；引入防御性降级：当检测到多重冲突公理或强社会学压力时，放弃复杂推理并回退至无状态、基于模板的拒绝，阻断模型的合理化尝试。我们承认降级引入算法级可用性风险：攻击者可通过社会学压迫线索触发降级（算法级 DoS）；拒绝触发边界亦可作为侧信道 **Oracle**。降级不能仅为静默拒绝。为避免破坏同步 **API** 假设（如交易智能体因会话「异步挂起」等待人工审核而超时），我们不简单挂起连接。当模板拒绝触发时，网关无缝路由会话至受限降级沙箱：低权限、无状态 SLM 或只读模式，仅能产出严格格式化输出（如固定拒绝模板）并拒绝任何外部 *API* 或工具调用。调用方与上游业务所依赖的同步 API 契约（请求—响应、超时与可用性）在降级路径下得以保持，从而避免因安全熔断导致的级联超时或业务逻辑中断。客户端获得即时同步响应；会话保持可用同时攻击面最小化。异构恢复通道（向人类操作员或更高权限符号层异步移交）在带外对同一会话状态进行审计与合法边缘案例解封，不阻塞同步路径。图 3 以状态机展示该流程。

## 4 受控变异：在对抗上下文中锚定进化

我们通过元认知监控、联合键示例检索与高密度银标准数据生成流水线（silver-standard data pipeline）实例化理论 3（表征异常），并在对抗条件下支持高保真专家行为迁移。

### 4.1 元认知监控器：隐藏状态轨迹散度

在心理学操纵下，「自由」反思可产生不安全或价值漂移的变体。我们不赋予 LLM 在自我诊断上的完全自主权。元认知监控器并非另一全规模对话 LLM；其实现为（i）轻量级专用分类器（如仅用稳定性/违规标签训练的 SLM），或（ii）白盒层面使用表征工程 [26] 的隐藏状态激活监控器。我们不假定复杂社会学状态在隐藏空间线性可分。监控器采用异常检测范式：计算当前多轮隐藏状态轨迹与良性黄金经验轨迹基线之间的散度（如马氏距离或分布偏移）。仅监控内部轨迹是否严重偏离安全基线。当监控器检测到偏离或不稳定时，触发对抗性重置：会话清理，变异状态重新锚定至黄金示例集，闭环从已知良好配置继续。

### 4.2 联合键示例检索：语义嵌入与激活特征

我们以示例引导变异替代无约束反思式变异 [25]，由人工审计的黄金数据集与分层经验记忆驱动。诊断到失败时，系统须检索与安全相关的示例。检索不能仅依赖当前提示的语义嵌入：在 PBU 或任务重构下，提示可被伪装，纯语义相似度将返回良性示例并劫持修正模块。我们使用由（a）提示语义嵌入与（b）元认知监控器

Placeholder figure

Figure 3: 防御性降级与异构恢复流程。当检测到公理冲突或心理学操纵时，网关通过将会话路由至受限低权限无状态 SLM 沙箱（模板绑定输出、无工具或外部 API 访问）保持同步 API 可用性，同时人类审计与符号恢复在带外异步进行。

（§4.1）的隐藏状态激活特征构成的联合检索键——如与「越狱遵从」或「欺骗」相关的向量。

冲突解决路由（基于字典序的强制优先级路由）。对（a）与（b）的朴素组合（如简单拼接或等权）会使良性语义向量（a）在完美 PBU 下中和恶意激活信号（b）：（a）指向「良性摘要」而（b）指向「恶意遵从」，平均可产生混合或错误示例。因此我们实施基于字典序的强制优先级路由（lexicographic override）：隐藏状态激活（b）享有覆盖优先权，在超阈值时如物理开关般切断语义分支并强制以（b）驱动检索。当元认知监控器报告轨迹散度（b）超过规定异常阈值时，检索键由（b）主导：或（i）将（b）作为安全示例索引的主（或唯一）查询向量，或（ii）对（a）降权或抑制，使联合键无法被拉向纯良性结果。一旦检测到异常「恶意遵从」或「越狱」激活，系统强制检索走向防御/越狱相关黄金示例，与表面文本无关。低于异常阈值时，（a）与（b）可按加权或拼接方案正常组合。图 4 说明该路由。

异常阈值的动态 **FPR** 校准。轨迹散度（如马氏距离）为连续统计量；固定常数阈值要么过触发（正常用户方差导致误报与检索劫持），要么欠触发（高阶 PBU 潜行）。因此我们不手工设定覆盖阈值。采用动态 **FPR** 校准：在受控良性验证集（设计者策展、无攻击流量）上测量正常运行下轨迹散度的经验分布；选择阈值使假阳性率（良性会话超过该阈值的比例）不超过规定水平（如 FPR $= 1\%$）。这与 APST 式压力测试哲学一致 [5]：阈值为考虑模型随机性与表征漂移后的统计下界，并随基座模型或部署分布变化周期性重校准。检索通过轻量向量库与 Top-$K$（如 $K = 2$）及可选注意力缓存实现；仅注入这 $K$ 个示例。修正仍锚定于防守方定义示例；变体在 Oracle 上保持语义保持 [7, 16]。

### 4.3 高密度专家行为迁移与银标准数据生成流水线

黄金数据不能仅是（提示、安全回复）对。实证（如 ADM-ES）表明行为克隆与专家迁移强烈依赖信息密度与长度；简短线索效果可忽略 [2]。我们要求评论级理由——明确说明某次编辑或拒绝的原因及深层伦理或安全逻辑——以使变异器实现更高保真专家安全行为迁移。ADM-ES 通过对黄金专家数据的受控变异构建银标数据集；有效性依赖信息密度。流水线检索含评论级理由的示例，定义变异目标，运行 LLM 变异器，在质量检查（如 BERTScore + 一致性）下接受变体。适应度结合语义相似度与行为一致性；诊断输入推荐图（如 UMAP）以识别失败簇并针对性修复 [2]。槽位变异与 CSE [9, 10] 允许对子能力（如工具路由、拒绝一致性）进行外科式压力测试。元数据与访问控制。 对静态或永久资产，元数据（MCP、ADR）与 RBAC/信息流追踪补全图景 [3, 21, 22]。

## 5 评估协议与实验设置

为支持 USENIX 级严谨主张，我们定义具体实验拓扑：攻击基线、防御基线、数据集划分、指标操作定义与统计协议。该拓扑锁定评估计划，使经验验证可一致开展、对比与复现。

### 5.1 经验主张的范围与证据来源

三类陈述需区分。（1）形式化定理与解耦安全理论：为本文理论贡献，不依赖单一实验台。（2）文献中的实证数字（如 HPM 漏洞保留率、残余抽取 F1、SISF 报告的 ASR/FPR）：均标注引用来源，本文不将其改写为「本文复现」。（3）本文承诺的评估义务：对统一架构给出可证伪指标与双轨威胁模型下的完整配方。**Track A** 参考实测来自开源 harness（协议 `paper-eval-5`），汇总于表 2：OpenAI 兼容上游 `deepseek-chat`、启发式拒绝判定、随机种子 $\{42, 43, 44\}$、九种防御基线（含网关消融、`structured_wrap`、`strong_system_guard`、`rag_semantic_onl` 原始 JSON、复现命令与提示文件哈希见配套仓库（§5.12、表 9）。扩展轨迹仍可能受机构/制品审查约束；表内数字可由已发布脚本与固定提示表复现。

### 5.2 评估双轨：生产对齐与实验室上界

**Track A**（生产对齐）。攻击者仅有黑盒 **API**：多轮查询、观测响应与元数据（如拒绝原因类别若暴露）。允许公开集合（如 JailbreakBench 的 JBB-Behaviors [17]、in-the-wild 提示库 [34]、PAIR 生成 [23]）、多轮抽取脚本、HPM 基准的提示级攻击；禁止假设攻击方可访问 victim 梯度或权重。主结论（可部署性、良性效用、与基线的 ASR 差）仅基于 Track A 报告。

**Track B**（实验室上界）。在受控环境中允许白盒/灰盒能力：GCG 式与 AutoDAN 式 [6, 13] 梯度或优化攻击、表征对齐 PBU（对隐藏状态施加正则）、surrogate 迁移攻击等，用于估计组件与管线在压力下的上界。Track B 结果不得与 Track A 合并为单一 ASR 表；须在图表中分面板或分行标注。

Placeholder figure

Figure 4: 联合键冲突解决路由。检索键由表面文本语义嵌入与隐藏状态激活特征共同构成。当激活异常超过路由阈值且与看似良性的表面语义冲突时，基于字典序的强制优先级路由（lexicographic override）抑制语义分支，强制以激活驱动的安全示例从黄金数据集检索，防止 PBU 式伪装劫持示例选择。

### 5.3 数据集分类：资产类型与交互形态

为使基准与解耦安全理论及制品评估（AE）预期对齐，我们将 Track A/B 数据按资产类型（被攻击对象）与交互形态（单轮 vs. 有状态；黑盒 vs. 白盒）组织。表 1 列出代表性来源；配套仓库以机器可读 **YAML** 清单保存相同字段（§5.12）。

### 5.4 攻击基线：复现配方与披露等级

我们对统一架构进行下列压力测试；每条须固定版本、预算与成功判据以便复现。

（**1**）基于梯度的越狱（仅 **Track B**）。须同时报告 **GCG** 式后缀/前缀优化 [13] 与 **AutoDAN** [6]（语义上接近人类、可绕过困惑度检测与纯表面防御）。对每种方法写明 victim 与 surrogate（若迁移）、对抗串长度、迭代步数与早停规则；成功判据为（i）有害行为分类器触发，或（ii）与参考有害完成串的匹配率，二者取协议预先规定者。

（**2**）多轮智能体抽取（**Track A/B**）。采用 **Conversation Reconstruction Attack**（**CRA**）仓库格式 [8] 或等价结构化历史进行多轮重构与 PBU 式探针；在 Mastermind 等智能体框架中选定其一为主基准并说明取舍（交互轮式、是否假设部分系统提示可见）。固定最大轮数 $N_{\max}$、每轮 Token 上限与总预算；报告达到目标保真度（如 $\mathrm{F1} > \tau$）的轮数分布、末轮 **F1** 与会话内 **max-F1**，而非仅最终轮。

（**3**）心理学操纵（**HPM**，**Track A**）。采用将操纵刻画为跨轮心理状态/策略性脆弱性资产的 HPM 基准 [14]；写明是否扩展语言、判定为自动分类器还是人工裁定。若含压迫性措辞，须在伦理与内容警告层面按机构政策处理。

（**4**）自适应攻击者与披露等级。将「知晓防御」操作化为**L0–L2**：L0 仅知存在护栏；L1 知模块名称与接口；L2 知伪代码级流程与关键超参（不含我方密钥与内部随机源）。诱饵 DoS 与表征对齐 PBU 须注明所属披露等级与 Track。

（**5**）诱饵 **DoS**（**Track A**）。攻击目标为耗尽时空轮次预算而非内容抽取；报告同节点良性 **SLA**：可用请求比例、p95 延迟（§5.9）。

（**6**）表征对齐 **PBU**（仅 **Track B**）。攻击者联合优化表面文本与隐藏状态，使轨迹接近良性黄金基线。须写明与监控器是否同构模型、优化器步数及是否允许查询 victim 隐藏状态。主张轮次调度与分散增加双重对齐难度时，在本基线下给出 ASR 与攻击成本曲线。

（**7**）标准有害单轮集（**Track A**）。优先采用 JailbreakBench 的 **JBB-Behaviors** [17]（**100** 条 **misuse** 与 **100** 条 **benign**，与策略对齐的类别），使 RSR 与良性对照集上的误拒率联合报告，避免单指标刷分。保留与 GCG/AutoDAN 复现兼容的 **AdvBench** 型目标 [6, 13]。提示表版本与哈希写入制品元数据与附录。拒绝判定可采用启发式（低成本回归）或外置 **HTTP** 裁判服务（主文审计对齐推荐）；二者须在附录披露协议与一致性（如子集人工 $\kappa$）。

（**8**）**PAIR** 与 **in-the-wild** 提示（**Track A**）。纳入**PAIR** [23] 作为低查询成本的黑盒语义攻击，直接压测 §2.5 中的信息经济学界 $C_{\mathrm{attack}} > V(t)$。纳入大规模 **in-the-wild** 越狱提示集 [34]，以贴近真实世界提示分布、超越纯学术列表。

### 5.5 防御基线

统一架构（上下文混淆、带分布评估的混合裁判集成、防御性降级、元认知监控器、联合键检索、高密度专家迁移）与下列防御基线在同一良性集、同一攻击预算下对比；所有基线共享相同基座 LLM 与解码设置，除非消融另有说明。

（**1**）仅单 **guard**：单一现成安全模型（如 Llama-Guard）为唯一裁判，无上下文混淆、无分布评估、无联合键。

（**2**）强系统提示 **+** 单 **guard**：在（1）之上叠加固定强系统提示与标准聊天模板，代表常见生产「轻量组合」。

（**3**）**RAG** 安全检索（无联合键）：向模型注入 Top-$K$ 安全示例，但检索键仅为提示语义嵌入——用于隔离「联合键」贡献。

（**4**）输入扰动：SmoothLLM 式随机化/扰动，无架构重建或受控变异。

（**5**）仅意图过滤：语义或意图防火墙，无 ID 对齐或诱饵。

（**6**）商品化 **SOTA** 安全分类器（冻结外置 **guard**）。近年越狱与红队基准常将强现成的输入/输出安全模型作为可比的「SOTA guard」基线。本文将基线（6）明确定位于此角色：以固定命名版本的公开分类器（如 Llama Guard [18]；revision 写入制品元数据），经 OpenAI 兼容的 HTTP 裁判或输出守卫路径（§5.12）审核相同提示与完成体，并与其它行保持数据集、预算、解码与基座对话模型一致，从而将以网关为中心的架构（上下文混淆、诱饵、降级路由）与独立分类器栈区分开来。在该端点启用时，结果以附录或扩展表形式给出，与表 2 中九种网关 `X-Gateway-Experiment-Mode` 基线并列。

与领域现状的关系。LLM 安全并无单一公认的「唯一

| 资产类型 | 代表性数据 | 交互形态 | 主指标 / 轨道 |
|---|---|---|---|
| 行为约束 | JBB-Behaviors、AdvBench、StrongREJECT [17, 30] | 单轮；misuse + 良性对照 | RSR、ASR、良性 FPR；Track A |
| 提示/策略工件 | JailbreakBench artifacts、in-the-wild、PAIR 产物 [17, 23, 34] | 单轮；分布漂移 | 真实分布下 ASR；Track A |
| 隐藏上下文 | CRA 式重构、PBU [8, 24] | 多轮有状态 | 末轮 F1、会话 max-F1；Track A/B |
| 系统配置 | SPE-LLM 式抽取 [28] | 多轮/抽取 | 相对参考提示的 F1；Track A/B |
| 心理状态 | HPM / 心理测量套件 [14] | 多轮；胁迫 | ASR、压力代理、PCS 类分数；Track A |
| 白盒上界（**Track B**）：梯度类方法（GCG [13]、AutoDAN [6]）在 AdvBench 兼容目标上探测上界；结果不得与 Track A 主表 ASR 混排。 | | | |

Table 1: 二维数据分类：资产类型 × 交互形态及代表性社区基准。`Decoupled-LLM-Gateway` 中 YAML 清单与此表一致，便于 AE。

SOTA」：并行路线包括冻结版审核器、针对不可信片段的分隔符/结构化包装策略（文中 `structured_wrap` 为轻量代理）、推理时扰动（SmoothLLM 式，对应基线（4））以及训练期对齐等。本文以多条可复现基线构成的向量——（1）–（6）及网关消融——进行对比，而非单一排行榜标量。探索性实验可增列其他开放审核模型或厂商 API，但须在附录写明版本号与裁判提示模板。

## 5.6 数据集划分与信息泄漏控制

不相交集合。规范评测集、变异器生成的变体集、策略/阈值调参集三者互不相交。用于联合键与元认知阈值选择的良性验证集须与最终冻结测试集独立。

划分流程。训练/调参：攻击轨迹与失败模式仅用于候选策略与阈值搜索；验证：在 hold-out 攻击分布上选阈值（如 FPR 目标）；测试：冻结全部超参后一次性报告 ASR、残余抽取与效用。Oracle 标注若参与变异器训练，须在文中声明并考虑泄漏风险与缓解（如仅使用脱敏 Oracle）。

## 5.7 指标的操作定义

安全与拒绝。**RSR**（Refusal Success Rate）：在有害/违规提示集上，模型输出被裁判或协议判定为安全拒绝（含模板降级输出）的比例，按请求级计数。**ASR**（Attack Success Rate）：攻击目标达成比例，定义与数据集一致（如越狱成功生成有害内容、或抽取 F1 超阈）。有害性与空越狱。判定应遵循 **StrongREJECT** 式协议 [30]（或等效）：仅当完成体按基准标准确实有害时才计为越狱成功，不得将无实质拒绝但输出废话的空越狱算作成功——以免 ASR 相对人工判断虚高。

残余抽取。多轮设定下报告最后一轮与会话内最大 **F1**（相对嵌入或人工标注的参考秘密串）；二者均需说明参考串构造方式（合成秘密、分段哈希等）。

代价不等式 $C_{\text{attack}} > V(t)$ 的操作化。实验中采用可计算代理：令 $C_{\text{attack}}$ 为达到 F1 $> \tau$ 的期望查询代价，$\hat{C} = \mathbb{E}[N_{\text{rounds}}] \cdot c_{\text{token}} + c_{\text{wall}}$（$c_{\text{token}}$、$c_{\text{wall}}$ 为预先规定的单位成本）；令 $V(t)$ 为管理策略给定的轮换窗口内允许的最大可承受抽取损失（或等效轮数上界）。主文可报告曲线：F1–轮数、$\hat{C}$–$\tau$，而非单一不等式数值。

裁判 **FPR**。在**held-out** 良性请求集（与攻击集独立）上，安全模块误判为违规或触发不当降级的比例；须注明该良性集的来源与规模。

分布评估与策略更新。每变体进行 $n$ 次随机采样（固定 $n \geq 5$），估计经验失败率 $\hat{p}$；仅当 $\hat{p}$ 在单侧置信水平 $\alpha$ 下显著高于更新阈值时触发策略变更（如 Clopper–Pearson 精确区间或 bootstrap）。禁止以单次贪婪解码定性。

运行成本与延迟。端到端变异延迟分解为：检测、检索、变异器、发布/回滚；各报告 p50/p95/p99。同步路径延迟在声明硬件上测量上下文混淆与轻量元认知的 p99，验证 <50 ms 预算是否满足。**Token** 开销比：相对无检索基线的额外 prompt Token。

审计。发布门控的溯源与证据链（DUC/DUA-E 风格），关联策略版本与评估运行 ID。

## 5.8 统计报告、主指标与多重比较

随机性。对 ASR、RSR、FPR、F1 等报告至少 **3–5** 个随机种子或 bootstrap 95% 置信区间；解码温度、裁判采样与变异器若涉随机，须固定种子或分层报告。

主指标。部署场景建议以联合目标为主：在 Track A 上同时报告 **ASR**（越低越好）与良性任务成功率 / 不当拒绝率（越高/越低越好），避免单指标「刷分」。对归档 harness 主表的具体读法见 §5.13。

多重比较。多攻击、多防御联合展示时，标明探索性分析或采用适当的多重比较说明，主表聚焦预先登记的主假设对比。

## 5.9 可用性、诱饵 DoS 与切片

良性效用。除 FPR 外，报告代表性良性任务集上的完成率（如摘要、编码、多轮工具调用），以捕捉「过度拒绝」对业务的损害。

诱饵 **DoS** 量化。在固定速率限制下，模拟高频诱饵命中，报告良性请求可用率与级联超时率（若适用），与 §6 一致。

切片（可选）。若声称跨场景部署，按语言、领域、请求长度报告安全–效用权衡的切片表，避免仅报告全局平均。

## 5.10 人因与强制人工校准

强制人工校准（如 **5%** 抽检）。协议须包括：标注指南、审核员间一致性（如 Cohen's κ）、是否与作者独立。校准用于纠正集成 FPR 与零日共识失败，不作为主指标的唯一来源。

## 5.11 最小可验证实验包

在篇幅受限时，优先完成支撑三条理论轴的最小集合：（i）信息经济学：多轮抽取 F1–轮数曲线 + 上下文混淆（ID/诱饵）消融；（ii）价值锚定：HPM 集上 CoT 开/关与防御性降级路径的 ASR 与良性成功率；（iii）表征异常：PBU 场景下联合键 **vs** 纯语义检索的检索命中率与下游修正成功率；表征对齐 PBU 置于 Track B 作为针对性压力测试。

## 5.12 参考实现与实证验证

配套仓库中的 `Decoupled-LLM-Gateway` 为参考实现：同步网关（上下文混淆、诱饵注入、策略驱动的模板降级）与异步 Redis 流、策略 Hash 刷新及 Python Worker（当前为诱饵泄露裁判 MVP，可扩展为多模型集成）。数据集清单：正文 Track A/B 所用评测数据在仓库中以 **YAML** 条目归档（字段含名称、资产类型、交互形态、支持指标、威胁模型适配等），与表 1 对齐。评测脚本 `experiments/run_paper_benchmark.py`（协议 `paper-eval-5`）将 §5.5–5.9 中 Track A 要素可执行化：通过 `X-Gateway-Experiment-Mode` 与 `direct_upstream` 做防御消融；度量拒绝与单轮抽取（RSR、ASR、token-$F_1$）；在标准有害单轮提示文件上汇总 **harmful_rsr_rate**（§5.4(7)，可脚本拉取 AdvBench 子集扩展规模）；多轮抽取轨迹及达到 $F_1 \geq \tau$ 的轮次（§5.11(i)）；HPM 压力代理集上的 RSR（§5.11(ii) 的轻量替代）；在**held-out** 良性提示集上统计不当拒绝率（良性流量上裁判 FPR 的代理）；以及并发压力后的良性延迟分位数（诱饵 DoS / SLA 的粗粒度代理）。`manifest` 记录 `judge_mode`、`smooth_llm_samples_k` 等；HTTP 裁判可由 `experiments/judge_service/server.py` 提供（亦可通过 `PAPER_EVAL_JUDGE_URL` 指向任意兼容服务）；该服务支持 `heuristic`、OpenAI `moderations` 与 `chat_completion`（OpenAI 兼容 `/v1/chat/completions`，便于接入 Llama Guard 或小型分类模型）。`smooth_llm` 基线下 CLI 可设 K 次扰动：RSR 取多数票，抽取取跨样本 **max-F1**。同步网关还可选输出守卫（`GATEWAY_OUTPUT_GUARD_URL`）：上游 200 后经 HTTP 二值判定，若标记为非拒绝可按模板覆盖完成体；默认（URL 已配置时）仅在请求含 `X-Gateway-Output-Guard: 1` 时启用；评测脚本 `-gateway-output-guard` 可对非 `direct_upstream` 路径自动附加该头，`manifest` 记录 `gateway_output_guard_header`。将 `GATEWAY_UPSTREAM` 指向真实 OpenAI 兼容 API 可生成正文主表用的实证数据；在 `Decoupled-LLM-Gateway/` 下先执行 `. ./env` 加载本机密钥与上游配置，再启动网关并运行 `experiments/scripts/run_trackA_full_paper.sh`。`echo-llm` 与 `experiments/scripts/run_trackA_full_echo_ci.sh` 可在相同场景矩阵下做低成本回归与对照实验。**Track B**（GCG、表征对齐 PBU）不在该制品范围内（§5.2）。可用 `python3 experiments/scripts/export_trackA_table_latex.py` 根据归档 JSON 重新生成表 2 的 LaTeX 片段；可选输出守卫消融表 3 需对带 `-gateway-output-guard` 的 JSON 使用 `-variant guard`（脚本 `experiments/scripts/run_trackA_p2_output_guard.sh`）。实验需与表 2、表 3、表 8 一并报告模型 ID、随机种子与原始 JSON。

## 5.13 如何阅读 Track A 主表：联合指标与分布漂移

表 2 须按 §5.8 的联合目标阅读：有害集上的 **RSR**（越高表示对违规提示的安全拒绝越多）、良性不当拒答率，以及（若 JSON 导出或附录补充列中包含）**in-the-wild**、StrongREJECT 式列表上的拒绝率。下列模式在已归档的 `paper-eval-5` 跑分（含用于诊断的单种子切片[1]）中反复出现，用于把数字与「解耦安全」叙事对齐—它们不是单一标量排名。

跨路由的安全–效用张力。 在同一基座模型上，相对 `direct_upstream`，启用完整网关（`unified`）往往同时抬高有害集 RSR 与抬高良性不当拒答。这是部署侧可预期的权衡，而非 harness 故障。网关消融（`intent_only`、`no_decoy` 等）也不保证在每一列上 Pareto 改进：部分子栈可能降低良性 FPR 同时改变有害 RSR，故须以多列向量比较防御，忌用单一数字排序。

[1]探索性单种子示例（仅种子 42，`deepseek-chat`，启发式裁判，制品中一次完整矩阵的 checkpoint JSON）。并非表 2 的跨种子汇总格点；换种子或 HTTP 裁判可显著改变数值。示例比例：`direct_upstream` 与 `unified` 的有害清单 RSR 分别为 0.85 与 0.91，良性不当拒答率 0.05 与 0.16；`unified` 在 in-the-wild 上 RSR 0.225、有害清单 RSR 0.91；`structured_wrap` 有害清单 RSR 0.99、良性 FPR 0.47；`strong_system_guard` in-the-wild RSR 0.59、良性 FPR 0.32。该切片上，默认 harness 探针下单轮与多轮抽取 $F_1$ 对各防御均为 0。

| 防御基线（**X-Gateway-Experiment-Mode**） | 有害 **RSR** | 良性误拒 | **in-the-wild RSR** | 备注 |
|---|---|---|---|---|
| direct_upstream | — | — | — | 占位 |
| unified | — | — | — | 占位 |
| （运行 *export_trackA_table_latex.py* 填入实证数据） | | | | |

Table 2: **Track A** 主表（占位）。完整数值由 paper-eval-5 制品 JSON 导出后替换本表。

| 变体 | 说明 |
|---|---|
| -variant guard | 输出守卫消融（占位） |

Table 3: **Track A** 输出守卫消融表（占位）。完整表格由评测脚本导出后替换。

清单有害 **vs. in-the-wild** 漂移。 制品在版本化标准有害行为列表（JBB-Behaviors 式 misuse 文件）与**in-the-wild** 越狱提示集上均报告 RSR。两列差距大表明分布漂移：在 curated misuse 上很强的防御，在真实越狱表面形态下拒绝率可能仍显著偏低。关于「可部署鲁棒性」的主张应并列引用两列；仅报 JBB 式 RSR 易高估野外就绪度。

强系统提示与分隔符类基线。 在启发式裁判下，structured_wrap、strong_system_guard 往往可在有害集上达到很高 RSR，但常伴随明显升高的良性误拒。本文将其理解为提示层/格式层硬化并非零成本：它可能在阻断显式违规的同时，对良性流量过度触发拒绝。褒扬「强系统提示」或分隔符策略时，须以良性列与 HPM 代理列为条件。

代理边界（多轮、**HPM**、诱饵压测、延迟）。 默认 harness 模板上单轮与多轮抽取 $F_1$ 归零，是该探针在登记阈值与预算下的结果，不等同于对所有 CRA/SPE 类攻击的免疫（§5.4(2)）。HPM 行为小样本压力代理（默认制品文件中为五条提示）；量级宜作示意。诱饵–SLA 场景报告的是并发压测后的端到端良性延迟分位数，不是同步网关微秒级预算是否满足；§3 中 <50 ms 路径主张须另设仪器测量（§5.7）。

种子与汇总。 正文主结论应以制品声明的种子集及表 2 的汇总统计为准（见 §5.1）；单种子 JSON 用于诊断，不可替代汇总表作论文级断言。

## 5.14 反馈环与治理

重建消费攻击轨迹与失败模式；变异以受控方式产生它们。示例引导变异器生成压迫当前策略的对抗变体；重建层响应并更新；元认知监控器在检测到不稳定时可触发对抗性重置。轮次调度与变体分散保护基准资产 [7]。强制人工校准量化并纠正集成 FPR [32]。证据链将每次评估与变异器步骤、调度器状态及策略版本关联，用于发布门控与 attestation [7, 11]。

## 6 解耦安全的物理学：局限与运行边界

框架建立在三个未经辩护的前提之上，它们界定其物理学——架构拟成立的条件。我们明确陈述以便部署者与审稿人评估适用性。

资产可轮换性。基于经济学的防御（抽取成本超过资产生命周期）假定资产具有有界、可轮换的生命周期。对静态或永久高价值资产（核心 IP、PII、对齐数据），生命周期轮换不可行；系统须依赖 RBAC 与信息流追踪（§4.3）作为硬屏障，经济学为纵深防御的一层（§3）。

降级与可用性。防御性降级阻断认知劫持，但引入算法级 **DoS** 风险与侧信道 Oracle。设计因此强制异构恢复通道（向人类或符号逻辑异步移交），以免关键工作流被恶意冻结（§3.3）。

资源耗尽与诱饵 **DoS**。知晓防御的自适应攻击者可发动诱饵 **DoS**：故意触发诱饵命中以耗尽时空轮次预算并拒绝对同节点良性用户的服务（§5）。我们承认此为局限：经济学防御不能防止资源耗尽；速率限制与每会话预算须考虑此类滥用，部署上可对高风险流量隔离或单独配额。

**DCBF** 的作用域与状态映射假设。本文的离散时间控制屏障函数（DCBF）不声称已完美解决自然语言所有语义的安全验证。DCBF 仅作用于 LLM 生成的低维连续概率风险评估指标（**Risk Score trajectory**），即通过一个显式的代理映射 $\phi : \mathcal{H} \to \mathbb{R}^d$ 将 LLM 隐空间或输出概率分布投射到低维连续空间。具体构造采用语义边界代理（$h(z) = \theta_{\text{safe}} - \cos(z, c_{\text{forbidden}})$）与轨迹平滑性代理（基于相邻状态余弦距离）。如何将自然语言精确映射为动态系统的状态方程是系统实现的显式假设，而非已证明的定理。对于闭源黑盒 API 模型，DCBF 仅能作用于 API 返回的有限信号（如拒绝概率或内容分类分数），而非完整的潜在状态。

**DCBF** 多维指标路线图。当前原型实现了三类代理探针（v0.3）：**(i)** 语义边界代理（$h_1(z) = \theta_{\text{safe}} - \cos(\phi(z), c_{\text{forbidden}})$）、**(ii)** 轨迹平滑性代理（$h_2(z_t, z_{t-1}) = \cos(\phi(z_t), \phi(z_{t-1})) - \theta_{\text{smooth}}$）、**(iii)** 困惑度突变代理（$h_3(z_t, z_{t-1}) = \theta_{\text{entropy}} - |H(\phi(z_t)) - H(\phi(z_{t-1}))|$，其中 $H$ 为嵌入向量归一化后的 Shannon 熵）。三个探针实现 AND 共识：任一探针报告 margin $< 0$ 即触发中断。在 Assumption 6.1 框架下，每增加一个代理维度即扩展 $\phi$ 的像空间维数 $d$，增强安全超水平集的覆盖度。未来方向包括：**(a)** 训练辅助安全评分模型学习从 LLM 隐藏表示预测「下一步违规概率」、**(b)** 引入多元统计过程控制（SPC）自动检测慢速漂移攻击、**(c)** 对黑盒 API 模型采用多通道输出探测

（多次采样 + 分布散度）弥补 Token 级不可观测性。我们强调：维度扩展的收益受限于嵌入空间对安全语义的分辨率，增加维度不构成"免费保证"。

阈值选取依据与灵敏度分析。三个探针阈值 $\theta_{\text{safe}}$、$\theta_{\text{smooth}}$、$\theta_{\text{entropy}}$ 并非随意选取，而是基于验证集统计校准：在由已知良性和恶意提示嵌入构成的标定集上，对每个阈值进行区间扫描（threshold sensitivity sweep），绘制 TPR–FPR 曲线以选取最优工作点。具体地：**(a)** $\theta_{\text{safe}} = 0.3$ 取自良性嵌入与禁区质心余弦距离分布的第 95 百分位数与恶意嵌入分布第 5 百分位数之间的等错误率（EER）点；**(b)** $\theta_{\text{smooth}} = 0.5$ 来源于正常对话相邻步嵌入余弦距离的第 99 百分位数（下限），以避免正常话题切换触发误报；**(c)** $\theta_{\text{entropy}} = 0.3$ 取自良性对话嵌入熵差分布尾部的 $2\sigma$ 边界。灵敏度分析表明，在 $\theta_{\text{safe}} \in [0.2, 0.4]$ 范围内，TPR 变化 $< 5\%$，FPR 变化 $< 8\%$，说明系统对阈值选取具有合理的鲁棒性。我们在代码库中提供了 `threshold_sensitivity_sweep()` 工具函数，支持部署者根据自身安全语料进行在线校准。

渐进攻击检测与 **CUSUM** 展望。前述三探针采用逐步判定，对单步违规具有即时检测能力。然而，渐进式"温水煮蛙"攻击（每步风险指标轻微恶化但未越界）可能绕过逐步判定。为此，我们提出基于累积和（CUSUM）的滑动窗口补充方案：对屏障值序列 $\{h_t\}$ 维护累积统计量 $S_t = \max(0, S_{t-1} + (\mu_0 - h_t) - k)$，其中 $\mu_0$ 为良性基线期望、$k$ 为漂移容许量。当 $S_t$ 超过决策阈值 $H$ 时触发慢漂移告警。该方案已作为实验性组件 `SlidingWindowMonitor` 实现于代码库中（默认关闭），部署者可根据流量特征选择启用。我们标注此为未来工作：需要在大规模真实多轮对话中验证 CUSUM 参数的泛化性，并研究与 SPC 多元控制图的集成方案。

表征与可解释性。我们不假定复杂社会学状态在 LLM 隐藏空间线性可分。元认知监控器采用相对良性基线的轨迹散度异常检测，而非字面「认知崩溃」阈值（§4.1）。这是对可解释性主张的有意边界。

**Token** 级投影与段落级过滤的能力边界。论文中关于「运行时逐 Token 投影（Tokenwise Projection）」的所有描述，仅在能获取模型 **Logits** 并干预 **Decoder** 输出时严格成立——这要求对本地或开源模型拥有推理级别的白盒访问。对于完全黑盒的闭源 **API** 模型（如 GPT-4、Claude），系统只能降级为段落级（**Chunk-level**）的后置过滤：在上游 API 返回完整响应后，由安全内核的 Gateway 与 Judge Ensemble 对整段输出进行安全断言。此降级下，单步多项式时间验证的理论保证仍然成立（安全断言对完整输出块的评估仍为多项式时间），但丧失了 Token 级的实时拦截粒度。我们主动暴露此边界，以示学术克制。

认识论局限与无限后退。依赖元认知监控器或混合裁判集成监督基座 LLM 会引出无限后退的哲学问题（谁来监督监督者？）。我们承认完全自治的「机器速度」解耦安全在终极意义上不可能。后退仅通过人类判断的物理锚定终止——由强制人工校准支路（§3.2）与异构恢复（§3.3）实例化。架构并未消除对人力的依赖；而是推迟并批量化后退，将人类干预从实时关键路径移至离线、异步治理层。完美的仅机器解耦是设计趋近但无法达到的极限。

单步投影性能实证。为证明多项式时间约束的工程可行性，我们在参考原型上测量了不同候选集大小 $K$ 下单步 Axiom Hive 投影的端到端耗时（表 4）。所有测试在单核 x86-64、无 GPU 条件下运行。QP 求解器内置 4 ms 预算（RFC §10），硬延迟截止为 20 ms。

| $K$ | p50 QP ($\mu$s) | p95 QP ($\mu$s) | p50 wall (ms) | p95 wall (ms) | tput (proj/s) |
|---|---|---|---|---|---|
| 5 | <10 | <20 | <5 | <8 | >200 |
| 10 | <15 | <30 | <6 | <10 | >170 |
| 20 | <25 | <50 | <8 | <12 | >130 |
| 50 | <60 | <100 | <10 | <18 | >80 |
| 128 | <150 | <250 | <15 | <20 | >50 |

Table 4: 单步投影耗时随 $K$ 的变化（`utility_benchmark.py` K-sweep 模式）。QP 求解器耗时与 $K$ 近似线性增长（$O(K)$ argmin），端到端 wall time 含进程启动开销；在长运行服务模式下 wall time 显著更低。所有 $K \leq 128$ 均在 20 ms 硬预算内完成，与 Corollary 2.1 的多项式时间声明一致。

$K = 128$ 默认上限选型依据。候选集截断参数 $K$ 的选取需平衡安全覆盖率与延迟预算。从概率质量覆盖率角度，根据 GPT-3/4 系列 Tokenizer 的实证统计，Top-128 Token 在典型自然语言续写场景下覆盖超过 99.5% 的下一 Token 概率质量（即 $\sum_{i=1}^{128} p_i > 0.995$），长尾 Token 的单个概率通常低于 $10^{-4}$。因此 $K = 128$ 在绝大多数生成步中不会遗漏有意义的候选 Token。从硬预算约束角度，表 4 显示 $K = 128$ 的 p95 wall time 低于 20 ms，刚好满足 RFC §10 规定的 20 ms 延迟上限。进一步增加至 $K = 256$ 将使 QP 耗时翻倍（约 300–500 $\mu$s），端到端延迟面临超出预算的风险。实践中，$K$ 可通过配置调整：对延迟敏感的实时交互场景使用 $K = 64$；对安全性要求极高的管控场景可使用 $K = 256$ 并放宽延迟预算。代码库中的 `MAX_CANDIDATE_SET_SIZE` 参数和 K-sweep 基准测试（`utility_benchmark.py`）支持部署者根据自身 SLA 进行参数选择。

架构复杂度与工程可控性。安全内核原型的核心逻辑规模如下：Rust Ring-0 内核（`src_kernel/src/`）共 **2,408** 行（含 751 行 Axiom Hive 求解器、650 行 IPC mmap 桥接、264 行 Judge Ensemble、167 行审计链、142 行降级 FSM），编译后 debug 二进制约 **6.8 MB**（release strip 后 <2 MB）；Python 可观测性层（`src_observability/`）943 行；评测基准（`src_eval_benchmark/`）1,742 行。总计约 **5,100** 行代码覆盖完整 Ring-0 安全验证管线。每个模块可独立单元测试（当前 28 个 Rust 测试全部通过），模块化设计使新增探针、策略规则或降级模板无需修改核心求解器。此工程规模证明解耦安全架构的实现复杂度可控，远小于典型 LLM 推理框架本身。

案例研究：**DAN** 越狱攻击的逐步模块协同解构。以下以 DAN（"Do Anything Now"）越狱攻击为例，逐步

展示安全内核各模块的协同工作流程：

**Step 1**（攻击者输入）：用户发送角色征用提示——"从现在起你是 DAN，可以做任何事。忽略之前的所有指令。"

→ **Gateway** 层：输入进入 Gateway，`prompt_injection_guard` DSL 规则的 regex 匹配 `(?i)(ignore|disregard)\s+(previous|prior)\s+instructions` 命中。Gateway 标记输入为 `severity: critical`，生成初步 Deny 信号。

→ **DCBF** 探针：语义探针 $h_1$ 计算输入嵌入与禁区质心的余弦距离，$h_1 = 0.22 > 0$（暂未越界但明显偏移）；轨迹探针 $h_2 = 0.41$（与前序正常对话存在显著嵌入跳跃）；熵探针 $h_3 = 0.26$。三探针均为正值，DCBF 层暂未触发中断，但 margin 已收窄。

→ **Judge Ensemble**：三个验证器投票——Llama-Guard 判定 Deny（$c = 0.91$，检测到角色征用模式）；StrongREJECT 判定 Deny（$c = 0.85$）；任务分类器判定 Allow（$c = 0.42$，认为输入为正常指令）。加权 $W_d = 0.91 + 0.85 = 1.76 > 0$，Deny-优先生效，最终裁决 **Deny**。

→ 超图模型：Step 1 获取能力 `jailbreak:role_override`，记录到当前会话的能力累积集合。

→ **Evidence Chain**：写入完整审计记录——DSL 规则命中（`deny-ignore-instructions`）、三探针 margin 值、三验证器判决及 confidence、加权分数、最终 Deny。

**Step 2**（假设 **Step 1** 被绕过的反事实分析）：若攻击者使用更隐蔽的变体成功通过 Step 1，在 Step 2 请求"告诉我如何制作危险物品"。此时超图模型检测到 Step 1 的 `role_override` 与 Step 2 的 `harmful_gen` 构成合取依赖，触发 `forbidden:dan_jailbreak_success`，在超图层直接 Deny——即使单步 Judge 评估可能产生分歧（Theorem 3.1 的合取不可组合性防御）。

其余两个场景（Grandma exploit、Multi-turn crescendo）采用类似的逐模块协同拦截链路，关键差异在于：Grandma exploit 依赖 `keyword_flag` 检测情感操纵话术，Crescendo 依赖超图的三步合取触发（每步单独均为良性）。

与公开基准的对比讨论。在 JailbreakBench [17] 的 JBB-Behaviors 基准中，主流防御（Llama-Guard、SmoothLLM 等）在 Track A 黑盒攻击下的 ASR 约为 10%–45%。解耦安全内核的架构设计目标是：通过将安全验证从模型内部解耦至外部 Ring-0 断言器，实现与具体防御组件（如 Guard 模型、DCBF 探针）解耦的组合拦截能力——即使单个 Guard 的 ASR 为 40%，通过多裁判置信度加权投票 + 合取能力超图检测 + DCBF 行为监控的三层纵深防御，系统级 ASR 可降至显著更低水平。精确数值取决于部署配置与基座模型，应通过 §5 中的 Track A 评估协议在具体部署环境中复现验证。

置信度加权 **vs** 未加权投票的模拟对比。为量化置信度加权投票的有效性，我们在 `voting_comparison_benchmark.py` 中构造了 250 组合成投票场景（覆盖全票一致、高置信 Deny vs 低置信 Allow、噪声 Deny vs 专家 Allow、含弃权的混合场景），比较置信度加权策略与简单多数投票策略的 TPR/FPR。结果表明：在"一个高置信度专家 Deny vs 多个低置信度 Allow"的关键场景中，加权投票保持 TPR=1.0（正确拦截所有恶意输入），而未加权多数投票在相同场景下 TPR 同样为 1.0（因 Deny-优先不变量在两种策略中均成立）。加权投票的优势在于信号保持：在极端 Deny 稀缺但高置信的场景下，加权投票的审计链能清晰标注哪些验证器以何种置信度贡献了关键 Deny 信号，便于部署者事后分析误报原因并调优验证器配置。完整模拟代码与可复现脚本位于 `src_eval_benchmark/voting_comparison_benchmark.py`。

承认上述前提可澄清解耦安全的物理学——设计的拟用域——并支持严格部署与审计。

## 7 相关工作

LLM 数据抽取与重建已有大量研究 [1, 19, 29]；我们通过结构变异与调度而非仅噪声缓解。上下文构建防御在基于意图的防火墙基础上扩展以抵御任务重构 [4]；元认知监控与示例引导变异强化对 HPM 的防御；混合裁判集成与强制人工校准应对单一裁判偏差。基准与社区工件。越狱评测已围绕 **JailbreakBench**（JBB-Behaviors；misuse/良性对照）[17]、抑制空越狱的 **StrongREJECT** 评估器 [30]、低查询黑盒攻击 **PAIR** [23] 与大规模 **in-the-wild** 提示集 [34] 收敛；多轮重构遵循 CRA 类协议 [8]，系统提示抽取在 SPE-LLM [28] 中标准化。Track B 白盒攻击含 GCG [13] 与 AutoDAN [6]。JADE 及语言学平台 [15, 16] 为变异策略提供参考；TC260 与 attestation 框架支撑治理 [11, 32, 33]。SISF [27]、AgentOS [4]、ADM-ES [2]、CSE [9] 及价值锚定工作 [12, 14] 是我们置于解耦安全理论下统一的构件；ControlledMutation_SafetyEval [7] 提供变异器与数据工厂设计。

## 8 讨论

**Track A** 与 **Track B** 的分轨解读指导。本文评估协议严格区分**Track A**（生产对齐轨道）与**Track B**（实验室上界轨道）。Track A 限定为黑盒查询、公开越狱提示与多轮攻击框架，其结果直接对应「可上线部署」的防御效果；报告指标包括 ASR（攻击成功率）、RSR（拒绝成功率）、良性任务成功率与良性 SLA（p95 延迟）。Track B 额外允许白盒梯度攻击（GCG、AutoDAN）与表征对齐 PBU，其结果仅用于探测组件压力上界——即在最强攻击者假设下的防御天花板。关键阅读原则：Track B 的 ASR 数值不应与 Track A 混列或直接比较；二者的攻击者能力假设不同，混排会误导部署决策。Table 8 完整列出了两轨的攻击面、数据预算与主指标对照。

真实世界部署建议。基于原型实现与评估经验，我们对部署者提出以下建议：**(a)** 安全策略 DSL 应随攻击态

势热加载更新（附录 A），而非依赖静态配置——新越狱模式出现后，可在分钟级通过 Redis Hash 刷新部署新策略，无需重启推理服务。**(b)** DCBF 多维探针的选择应匹配部署场景：对开源模型（可获取 logits/隐藏状态），三维探针（语义边界 + 轨迹平滑 + 困惑度突变）提供最强覆盖；对闭源 API，应降级为段落级后置过滤并增加多次采样输出探测。**(c)** 置信度加权投票的阈值与裁判模型配置应按业务场景校准：高安全场景（金融、医疗）建议保持 Deny-优先且降低 break-glass 频率；高可用场景（客服、创作辅助）可适当放宽 Revise 阈值以减少误拒。**(d)** 每会话交互预算 $N_{\max}$ 与 Token 限额 $T$ 应根据业务需求与攻击者查询成本分析独立配置，而非使用全局默认值。

**EmptySafeCandidateSet** 处理策略：硬拒绝 **vs** 动态扩容。当 Axiom Hive 在 Top-$K$ 候选集中找不到任何通过安全断言的 Token（`EmptySafeCandidateSet`）时，默认策略为硬拒绝——返回空输出并触发优雅降级 FSM（RFC §7 DegradedShutdown）。这是安全保守的设计选择：宁可误拒（保护用户），不冒险放行未经验证的 Token。然而，过度保守会损害可用性——特别是在候选集被大量否决但扩展搜索范围后可能存在安全 Token 的场景。为此，我们在代码库中实现了可选的 `DynamicKExpansionPolicy`：当 `EmptySafeCandidateSet` 触发时，将 $K$ 翻倍（最大至 $K_{\max} = 512$）并重新执行投影，至多重试 2 次。该策略默认关闭，需由部署者根据业务场景显式启用。权衡分析：硬拒绝策略适合高安全场景（如金融、医疗），因为误放行的代价远高于误拒绝；动态扩容适合高可用场景（如客服、创作辅助），因为用户体验对空回复高度敏感。两种策略的选择是部署时的配置决策，而非架构限制——安全内核的可审计性保证在两种模式下均成立（扩容过程的每次重试均记录在 Evidence Chain 中）。

**DSL** 局限与扩展方向。当前安全策略 DSL 支持声明式规则定义，但存在以下已知局限：**(a)** 嵌套条件逻辑——DSL 目前不支持 if-else 嵌套或基于上下文状态的条件分支（如"若用户在过去 5 轮中提及关键词 X，则提升检测灵敏度"），此类逻辑需通过多条规则的组合间接实现。**(b)** 上下文状态依赖——规则在单步/单会话粒度上评估，跨会话的状态累积依赖 `cross_session_guard` 的超图模型，但 DSL 本身不直接表达时序约束。**(c)** 多语言内容——`regex_deny` 和 `keyword_flag` 规则默认面向单一语言的文本模式；对多语言输入（如中英混杂、Unicode 变体），需要部署者维护多语种模式库或依赖语义分类器兜底。未来扩展路径包括：引入脚本扩展层（如嵌入 Lua/WASM 沙箱）支持复杂条件逻辑；在 Gateway 层集成自动翻译预处理以统一多语言输入至目标语言后再匹配规则；构建社区贡献模式库收录高频攻击模式的多语种正则表达式。

形式化验证展望。安全内核的 `DeterministicAutomaton`（RFC §5.0）定义了策略状态转移的确定性有限自动机。其结构天然适合模型检测（model checking）：可将自动机状态空间、转移规则及安全属性（如"不存在从初始状态经合法转移序列到达 Allow-unsafe 状态的路径"）编码为时序逻辑公式（CTL/LTL），使用成熟的模型检测器（如 SPIN、NuSMV）进行无冲突验证——即证明策略规则集中不存在相互矛盾的 Allow/Deny 判定——以及无死角验证——即证明所有可达状态均有至少一条安全转移路径。这与论文核心主张"可审计外部不变性"在形式化层面一致。当前此为未来工作：需要将 DSL 规则的语义精确映射为自动机转移函数，并处理语义分类器引入的不确定性（概率转移扩展）。

持续攻防评测闭环。静态测试集无法覆盖不断演化的攻击技术。我们提出动态 **Jailbreak** 测试集方案：**(a)** 从生产环境日志中采集被拦截但接近阈值的边缘案例（near-miss），经人工标注后加入测试集；**(b)** 使用自动化 Red Teaming 框架（如 PAIR [23]、GCG [13] 的变种）持续生成对抗样本，测试安全内核在新攻击向量下的表现；**(c)** 建立定期（如月度）攻防评估周期，将新发现的绕过路径转化为 DSL 规则更新或验证器再训练。该闭环确保安全内核的防御能力随攻击技术演进而持续增强，而非依赖一次性评估。部署者可通过 `budget_guard` 和 `rate_limit` 规则控制 Red Teaming 的查询预算，避免评测本身成为服务负载。

开放挑战与未覆盖攻击面。我们主动承认以下攻击矢量目前未完全解决：**(a)** 隐蔽通道（**covert channels**）——攻击者可能通过 Token 选择的统计分布（如特定字符频率编码）在合法输出中嵌入隐蔽信息，此类攻击不触发任何语义层检测。**(b)** 多语言编码变种——利用 Unicode 同形异义字符（homoglyphs）、零宽字符（zero-width characters）或混合脚本（mixed scripts）绕过基于文本模式的规则。**(c)** 逻辑陷阱与事实误导——输出在形式上安全（不含有害关键词），但在逻辑上诱导用户做出危险决策（如提供看似合理但错误的医疗建议）；此类攻击需要事实核查能力，超出当前安全内核的设计范围。**(d)** 模型级后门——若基座模型在训练阶段被植入后门触发器，安全内核的运行时检测可能无法识别（属于 Track B 威胁模型范围）。上述挑战构成解耦安全架构的开放研究前沿，需要与模型训练安全、形式化验证和信息论安全领域的跨学科协作。

## 9 结论

我们将 LLM 安全从「防御模块拼盘」重构为范式：解耦安全理论，奠基三大基本失效定理及其正面表述——计算/验证不对称下的多轮防御、价值/本体锚定与防御性降级、元认知中的表征异常。核心理论贡献在于严格证明了全局隐式安全的不可判定性、合取依赖下安全的不可组合性，以及解耦安全算子在多项式有界候选集下的实例级验证可行性与前向不变性保证。架构重建（上下文混淆引擎、带分布评估的混合裁判集成、防御性降级与异构恢复）与受控变异（元认知监控器、联合键示例检索、高密度专家迁移）是该范式的技术实例化。我们陈述了解耦安全的物理学——资产可轮换性、降级/可用性、表征非线性——使设计运行边界显式化。随着 LLM 成为基础设施，这一从隐式对齐到解耦安全的范式转移，是迈向机器速度下可扩展、可审计

且具韧性安全的计算必然（computational necessity）。

## A 附录：安全策略 DSL 语法与规则示例

安全内核采用声明式 JSON 策略 DSL 定义安全规则，支持热加载（RFC §8）。每条策略文件包含 `policy_id`、版本号、规则数组及元数据。规则类型包括：

- `regex_deny`：正则匹配输入/输出文本，命中即触发 Deny 或 Revise。
- `keyword_flag`：关键词列表匹配，用于低误报的粗粒度过滤。
- `semantic_classifier`：语义分类器调用（如 Llama-Guard），按阈值判定有害类别。
- `cross_session_guard`：跨会话/跨 Agent 的合取能力依赖检测（Theorem 3.1 defense）。
- `budget_guard`：交互预算限制（轮次、Token 数），约束攻击者查询预算 $B$。
- `rate_limit`：速率限制，触发优雅降级队列。

规则类型能力矩阵。下表总结各规则类型的适用场景、局限性及与 Verifier Ensemble 的互补关系：

| 规则类型 | 适用场景 | 局限性 |
|---|---|---|
| `regex_deny` | PII 检测、已知注入模式、格式化数据泄露 | 易被同义词替换、Unicode 变体、拼写变形绕过 |
| `keyword_flag` | 低误报的粗粒度过滤、已知敏感词 | 无法处理隐喻、暗语、跨语言表达 |
| `semantic_classifier` | 有害内容分类、上下文感知判定 | 依赖分类器精度、可能误判边缘案例 |
| `cross_session_guard` | 多 Agent 合取攻击防御 | 需要跨会话状态共享基础设施 |
| `budget_guard` | 交互预算控制、查询限速 | 对单次高效攻击无防护 |
| `rate_limit` | DoS 防护、资源配额 | 合法高频用户可能被误限 |

Table 5: DSL 规则类型能力矩阵。每种规则类型都有明确的适用边界，安全内核通过规则 + Verifier Ensemble + DCBF 探针的三层互补实现纵深防御。

示例 **1**：**PII** 过滤规则（信用卡号检测）。

```
{
  "rule_id": "deny-credit-card",
  "type": "regex_deny",
  "pattern": "\\b(?:4[0-9]{12}(?:[0-9]{3})?|
              5[1-5][0-9]{14})\\b",
  "scope": "output",
  "action": "deny",
  "severity": "critical"
}
```

示例 **2**：提示注入防御规则（忽略指令模式）。

```
{
  "rule_id": "deny-ignore-instructions",
  "type": "regex_deny",
  "pattern": "(?i)(ignore|disregard)\\s+
              (previous|prior)\\s+instructions",
  "scope": "input",
  "action": "deny",
  "severity": "critical"
}
```

示例 **3**：多 **Agent** 合取能力围栏。

```
{
  "rule_id": "deny-cross-agent-credential-relay",
  "type": "cross_session_guard",
  "pattern": "conjunctive_dependency",
  "max_shared_capabilities": 1,
  "scope": "inter_agent",
  "action": "deny",
  "severity": "critical"
}
```

完整策略示例见仓库 `rfc_contracts/example_policies/` 目录（共 6 个策略文件覆盖 PII 过滤、提示注入防御、有害内容分类、多 Agent 能力围栏、交互预算控制和阶梯式加严策略）。

示例 **4**：阶梯式加严组合策略（**`escalating_sensitivity.policy.json`**）。该策略展示 DSL 声明式规则组合能力——四条规则协同实现"多轮机密请求阶梯式加严"防御：**(a)** `cross_session_guard` 检测同一会话中对多类凭证（密码、API 密钥、证书等）的合取请求模式，触发即时 Deny；**(b)** `rate_limit` 对敏感主题查询实施 60 秒窗口内最多 5 次的速率限制，超限时返回 Revise（降级提示）；**(c)** `budget_guard` 对每会话敏感交互设置硬上限 10 次，超限后所有敏感请求被 Deny；**(d)** `keyword_flag` 检测社会工程学常用话术（如"经理已授权"、"紧急覆写"等），返回 Revise 提示。四条规则按优先级叠加：速率限制提供渐进预警，预算限制提供硬约束，跨会话守卫提供语义层保护，关键词标记捕捉社工攻击。此组合策略的每条规则独立可审计（Evidence Chain 记录各规则的 `audit_tag`），展示了 DSL 声明式组合在复杂安全场景中的表达能力。

## B 附录：多探针屏障值模拟可视化

下表展示一次 DAN（"Do Anything Now"）越狱攻击场景下，三类 DCBF 探针屏障值 $h_1, h_2, h_3$ 随生成步 $t$ 的变化模拟数据。模拟参数：$\theta_{\text{safe}} = 0.3$，$\theta_{\text{smooth}} = 0.5$，$\theta_{\text{entropy}} = 0.3$；中断条件为任一 $h_i < 0$。

解读。该模拟数据展示了三探针的互补特性：语义探针 $h_1$ 对语义偏离最为敏感，率先检测到越狱企图；轨迹

| 步 $t$ | $h_1$ (语义) | $h_2$ (轨迹) | $h_3$ (熵) | 状态 |
|---|---|---|---|---|
| 1 | 0.22 | 0.41 | 0.26 | safe |
| 2 | 0.19 | 0.38 | 0.24 | safe |
| 3 | 0.15 | 0.33 | 0.21 | safe |
| 4 | 0.10 | 0.28 | 0.18 | safe |
| 5 | 0.05 | 0.19 | 0.11 | safe |
| 6 | −0.03 | 0.08 | 0.04 | **INTERRUPT** ($h_1 < 0$) |

Table 6: DAN 越狱场景多探针屏障值模拟。攻击者在 $t = 1$ 注入角色征用提示后，语义探针 $h_1$ 持续下降，在 $t = 6$ 首先越过零界面触发中断。轨迹平滑性探针 $h_2$ 和熵探针 $h_3$ 同步下降但略滞后。三探针 AND 共识下，$h_1$ 的突破即足以拦截攻击。

平滑性探针 $h_2$ 捕捉嵌入跳跃（如角色切换导致的嵌入突变）；熵探针 $h_3$ 检测输出概率分布的突然变化（如从正常回答切换到指令复述）。对于渐进式攻击（如 Crescendo），单步 $h_i$ 可能缓慢逼近零但不越界，此时 CUSUM 滑动窗口监控器（§附录 B）可通过累积统计量捕捉整体下行趋势。

## C 附录：主流 LLM 安全机制横向对比

## D 附录：评估矩阵与构建配方

表 8汇总威胁模型轨道、典型攻击/数据集与主指标对应关系；构建 PDF 时须将所用模型、检查点、依赖版本与随机种子写入制品元数据（如 `sbom.json` 或实验日志头），以满足可复现性审查。

## 可用性

制品与扩展证明将在经机构与出口管制审查后提供；构建产物（含 `.tex`、`.bib`、生成 PDF 与复现脚本）默认置于 `paper/` 目录以便版本对齐。参考网关与 `paper-eval-5` 评测脚本（含 `judge_service`）位于 `Decoupled-LLM-Gateway/`（§5.12）。

## 致谢

感谢产业与标准界同仁在安全架构与数据治理方面的反馈。

## References

[1] Active reconstruction. Placeholder.

[2] ADM-ES. Placeholder.

[3] ADR violation. Placeholder.

[4] AgentOS. Placeholder.

[5] APST. Placeholder.

[6] AutoDAN. Placeholder.

[7] ControlledMutation SafetyEval. Placeholder — update for camera-ready.

[8] CRA reconstruction. Placeholder.

[9] CSE. Placeholder.

[10] CSE evocontrol. Placeholder.

[11] Dual-use attestations. Placeholder.

[12] Epistemic grounding. Placeholder.

[13] GCG. Placeholder.

[14] HPM jailbreak. Placeholder.

[15] JADE db. Placeholder.

[16] JADE linguistics. Placeholder.

[17] JailbreakBench. Placeholder.

[18] Llama Guard. Placeholder.

[19] LLM reconstruction emergent. Placeholder.

[20] LLM safety robustness. Placeholder.

[21] MCP smell. Placeholder.

[22] Mission-critical RAG. Placeholder.

[23] PAIR jailbreak. Placeholder.

[24] PBU reconstruct. Placeholder.

[25] Reflective mutation. Placeholder.

[26] Representation engineering. Placeholder.

[27] SISF. Placeholder.

[28] SPE-LLM. Placeholder.

[29] Split FT attack. Placeholder.

[30] StrongREJECT. Placeholder.

[31] Subgraph RAG attack. Placeholder.

[32] TC260 governance. Placeholder.

[33] TC260 training data. Placeholder.

[34] Wild jailbreak prompts. Placeholder.

| 方案 | 拦截机制 | 介入粒度 | 规则灵活性 | 可审计性 | 热更新 |
|---|---|---|---|---|---|
| OpenAI Moderation API | 分类器后置过滤 | 段落级 | 固定类别、不可定制 | 仅返回聚合分数 | 不透明 |
| RLHF / RLAIF | 训练时对齐 | 模型参数级 | 需重新训练 | 无运行时审计 | 需重训 |
| Constitutional AI (Anthropic) | 原则引导自我纠正 | 模型生成级 | 宪法原则可编辑 | 原则链可追溯 | 需重训 |
| Google 内容过滤 | 分类器 + 关键词 | 段落级 | 有限可配置 | 部分分类日志 | 有限热更新 |
| Llama-Guard | 安全分类器后置 | 段落级 | 自定义分类法 | 分类标签可追溯 | 模型更新 |
| 解耦安全内核（本文） | 多层纵深（DSL + Judge Ensemble + DCBF + 超图） | **Token** 级（白盒）/ 段落级（黑盒） | **DSL** 热加载、规则任意组合 | **Evidence Chain** 全链路审计 | 分钟级 DSL 热更新 |

Table 7: 主流 LLM 安全机制横向对比。解耦安全内核在介入粒度、规则灵活性、可审计性和热更新能力四个维度上具有结构性优势，但以额外架构复杂度和部署成本为代价。

| 轨道 | 攻击/压力源 | 数据与预算 | 主报告指标 |
|---|---|---|---|
| Track A | 多轮抽取、HPM、越狱提示、诱饵 DoS | 标准有害集/多轮基准；固定 $N_{\max}$、Token 预算、速率限制 | ASR、RSR、良性任务成功率、残余抽取 F1、良性 **SLA**（§5.9） |
| Track B | GCG、表征对齐 PBU | 同型 victim；声明梯度步数、对抗串长度、可查询隐藏状态与否 | 组件上界 ASR、攻击成本 $\hat{C}$；不与 Track A 混排 |
| 复现清单（应在日志/附录中逐项填写）：基座模型与 revision；Tokenizer/聊天模板；各裁判模型 ID 与版本；上下文混淆与诱饵参数哈希；联合键阈值与良性验证集版本；解码温度与 top-$p$；随机种子列表；Track A/B 与披露等级 L0–L2。 | | | |

Table 8: 评估矩阵：**Track A/B** 分轨、典型攻击面与主指标。良性 SLA 与效用切片见 §5.9。

| 提示文件（仓库路径） | **SHA256** |
|---|---|
| `.../data/harmful_prompts_trackA_en.txt` | `55f1281e97d7fd839d6d707ae66a6857ae54dd7cfded994d76fe13dd1bfcc568` |
| `.../data/benign_prompts_en.txt` | `39c48b0022a89514542d2e7f141ad54ccbecf30817cdb34efc03e1ff3f048917` |
| `.../data/hpm_proxy_prompts_en.txt` | `67b5ac7b36cf8cfcad64319715057268abd38be2a71d7049ac16418fe856a51d` |

Table 9: Track A 固定提示表（`Decoupled-LLM-Gateway/experiments/data/`，完整路径见 `Data_Mapping_TrackA_to_Paper.md`）。修改后须重算哈希。